

WEEK 01 Cybersecurity Concepts

Introduction to Cybersecurity



Introduction to Cybersecurity

INTRO

Course Overview



About the Course

■ Cybersecurity is about **protecting** digital assets and systems, even in the presence of **adversaries**.



Learning Contents

■ In this course, you will explore five major areas of cybersecurity:

Concepts and basic **Cryptography** ①



② **Authentication** and **Access control**



Network Security and **Protocols** ③



④ **Software, Malware, and Databases**



Cloud, AI, Risk, and Privacy ⑤



Learning Objectives

■ By the end of the course, you will be able to:

- 1 **Explain** core cybersecurity concepts, terminology, requirements, principles, and cryptography basics.
- 2 **Apply** user authentication and access control mechanisms.
- 3 **Describe** network defenses and real-world security protocols.
- 4 **Analyze** software flaws, malware, and database vulnerabilities.
- 5 **Evaluate** cloud and AI security, risk management, and privacy protection.

Grading

Attendance

10%

**Midterm
Exam**

20%

**Final
Exam**

30%

Assignments

30%

Participation

10%

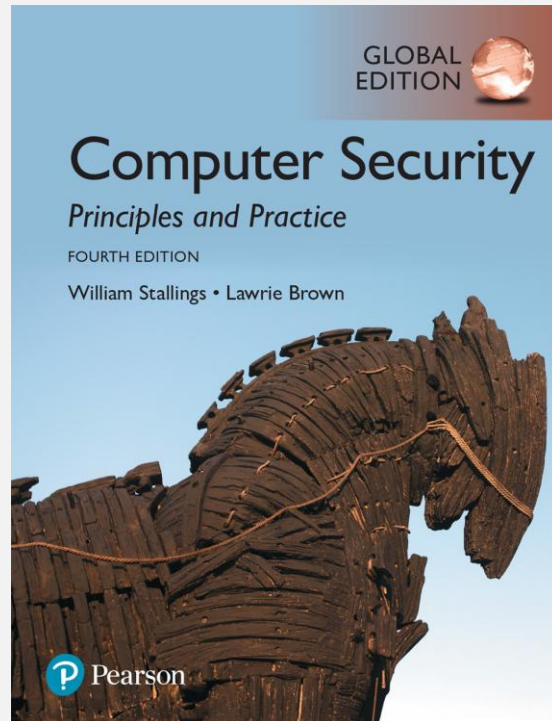
- Selected-Responses (SRs)
- Constructed-Responses (CRs)

- 2 Assignments
- Notice Board

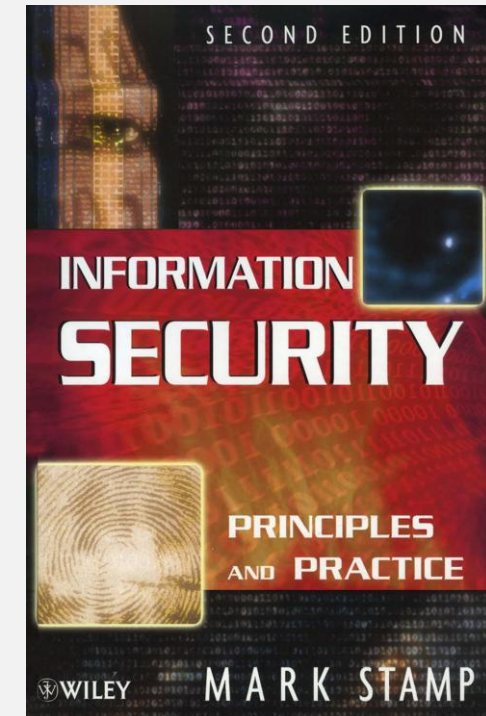
- Discussions

References

William Stallings, Lawrie Brown, **Computer Security: Principles and Practice**, 4th Edition, Pearson, 2018, 778 pp., ISBN 978-0-13-479410-5.



Mark Stamp, **Information Security: Principles and Practice**, 2nd Edition, John Wiley & Sons, 2011, 606 pp., ISBN 978-0-470-62639-9.



Introduction to Cybersecurity

UNIT 01.

Cybersecurity Concepts



Learning Objectives

■ By the end of this week, you will be able to:

- 1 Define core **cybersecurity concepts** and **terminology**.
- 2 Explain the **CIA triad** together with **authenticity, accountability, and reliability**.
- 3 Analyze the **relationships** among security concepts, and analyze a system's **attack surfaces** and **trees**.

UNIT

01

Cybersecurity Concepts

This unit helps you understand:

- Definition of Cybersecurity
- Cast of Characters
- Security Goals

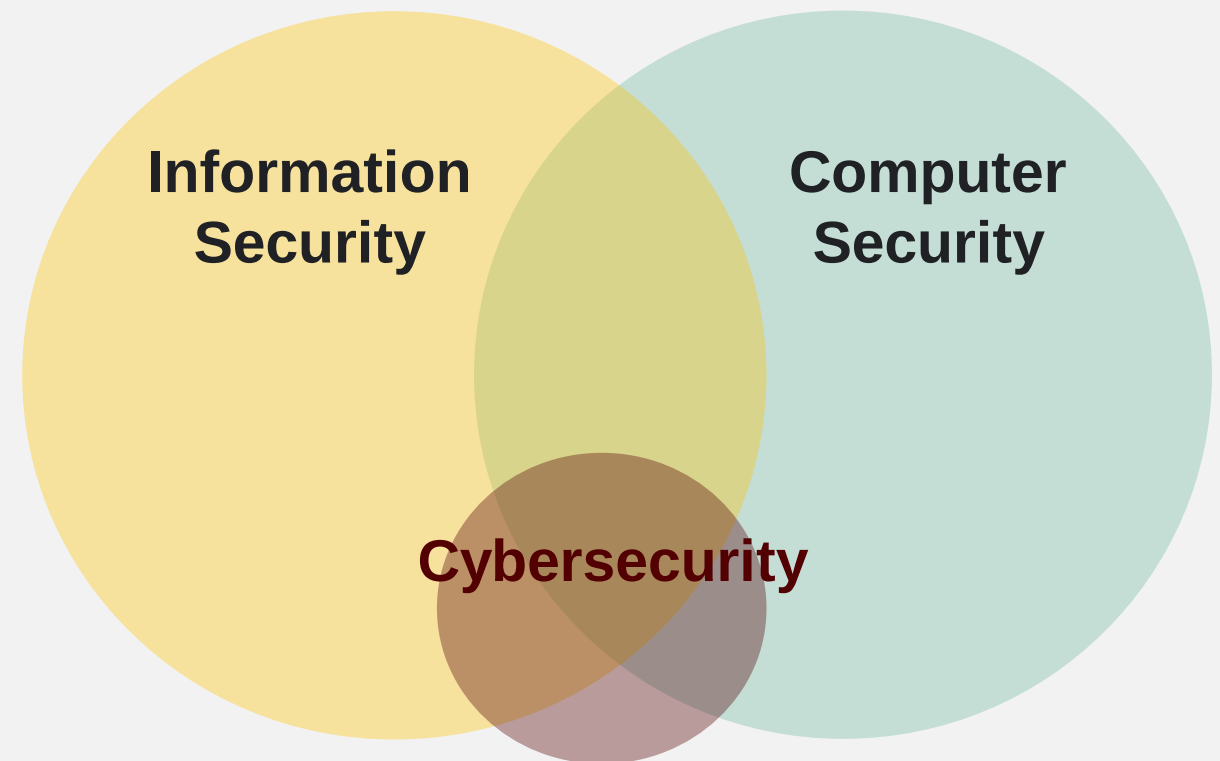
Definition of Cybersecurity

Cybersecurity

“The ability to protect or defend the use of cyberspace from cyber attacks.”

- NISTIR 8170

Related Terminologies

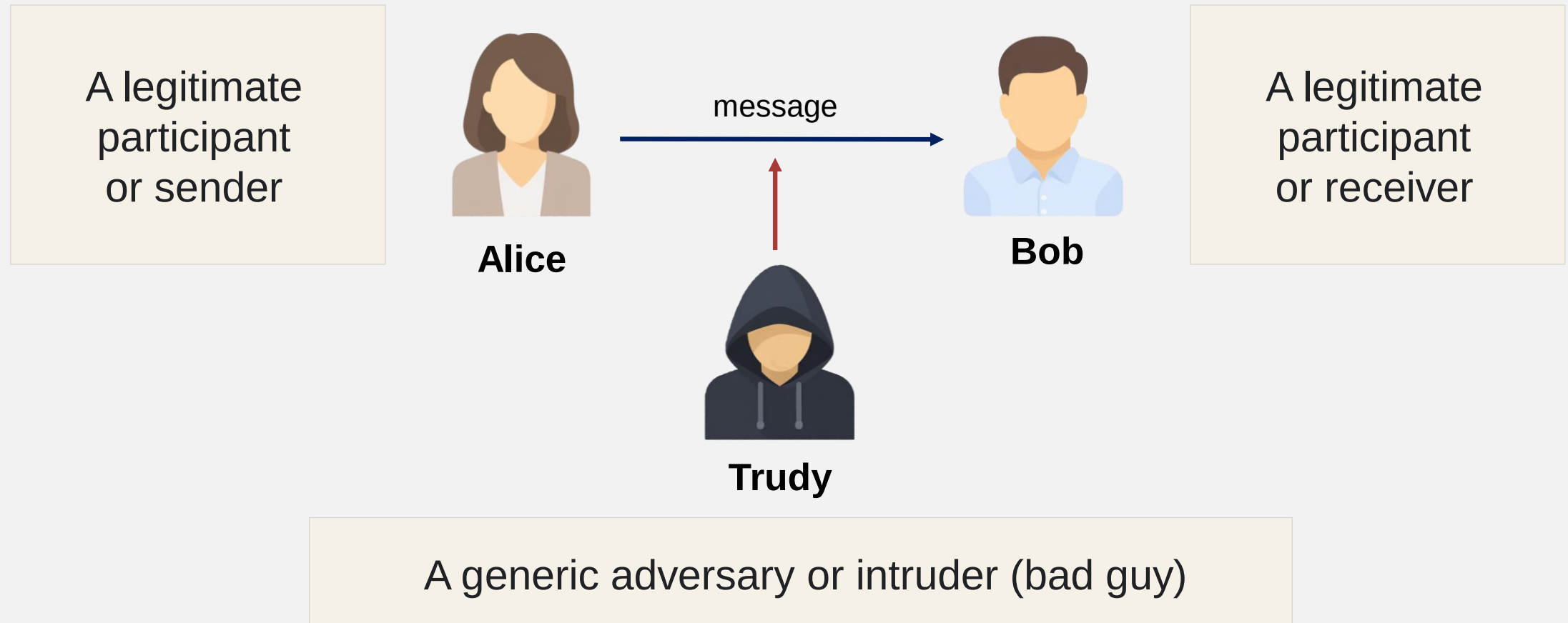


Definition of Cybersecurity

Criterion	Cybersecurity	Information Security	Computer Security
Definition	"The ability to protect or defend the use of cyberspace from cyber attacks."	"The protection of information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction in order to provide confidentiality, integrity, and availability."	"Measures and controls that ensure confidentiality, integrity, and availability of the information processed and stored by a computer."
Reference	NISTIR 8170	NIST FIPS 200	CNSSI 4009-2015
Primary Focus	The secure use of cyberspace	Information and information systems	Computer-based processing and storage
Typical Scope	Connected systems, networks, services, and communications	Information in any form and the systems that handle it	Computer hardware, software, processing, and stored information

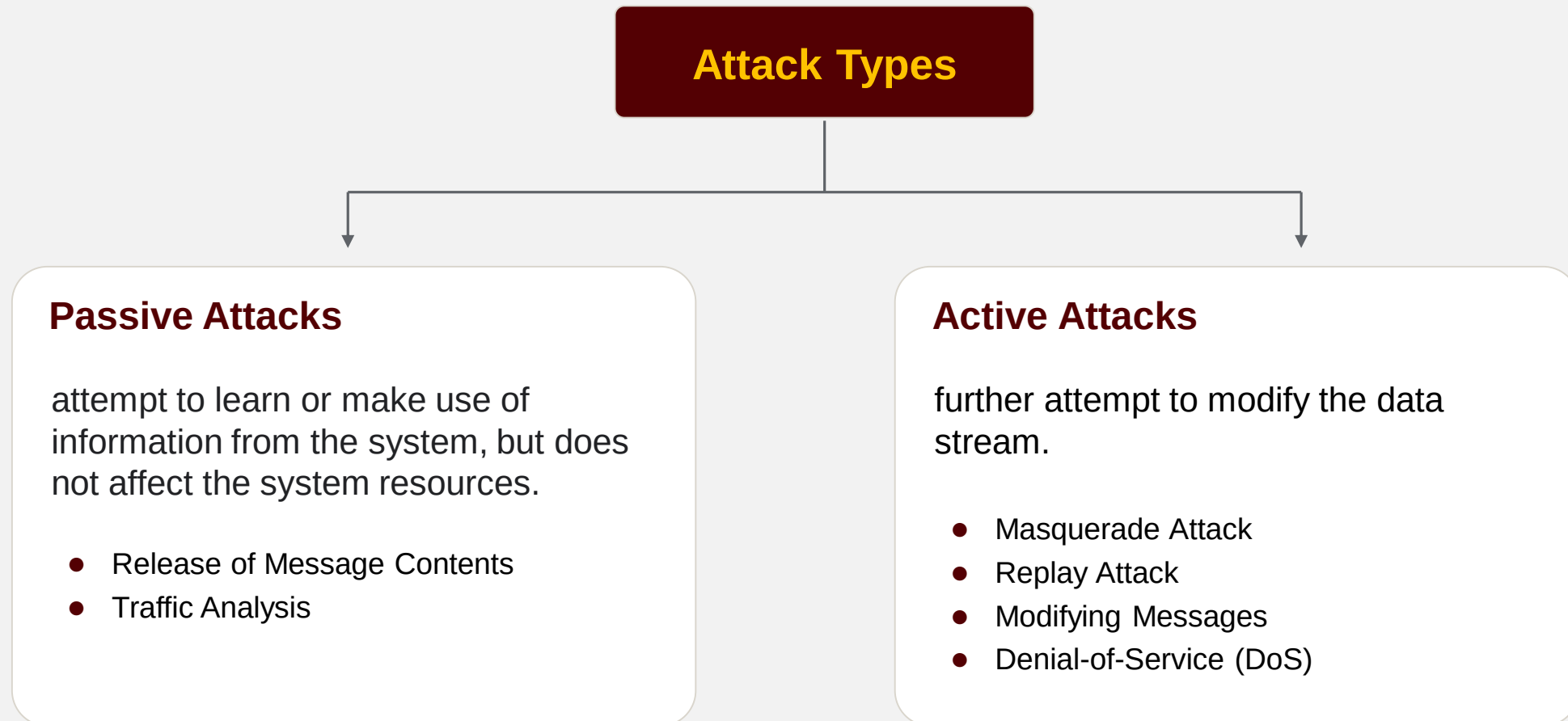
Cast of Characters

■ In cybersecurity, we often consider the following entities:



Cast of Characters

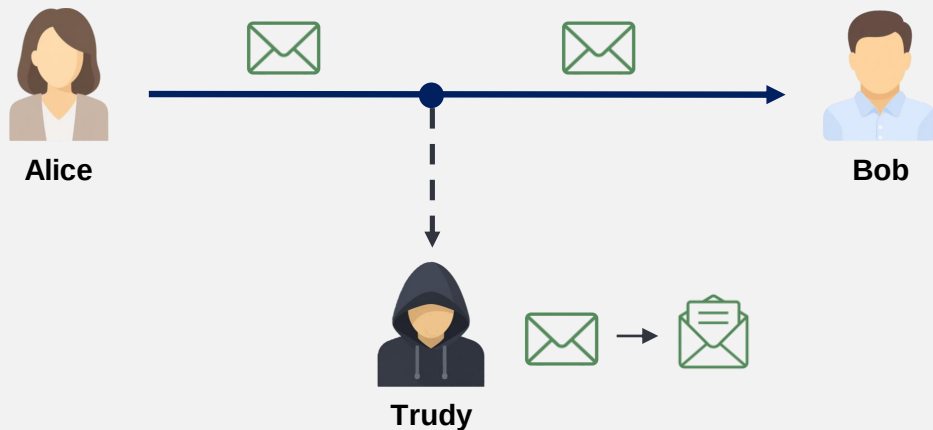
What Trudy can do:



Cast of Characters

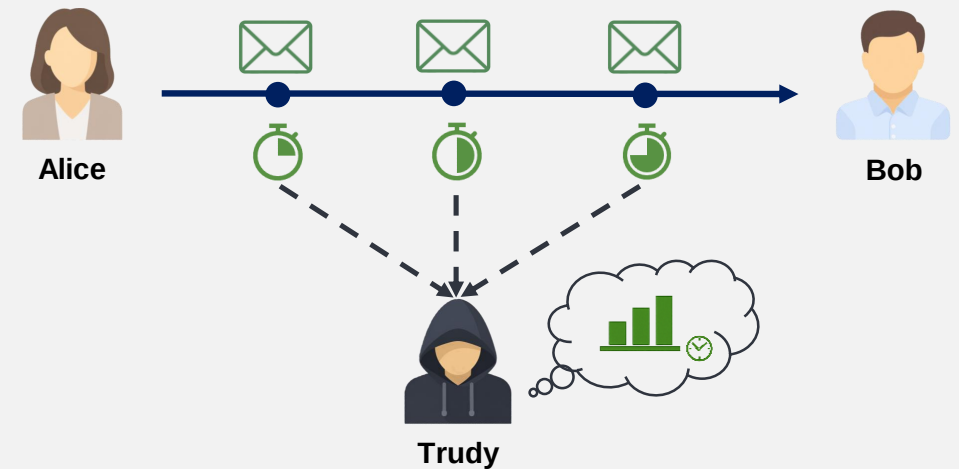
- **Release of Message Contents**

- a passive attack that learns the contents of sensitive or confidential transmissions.



- **Traffic Analysis**

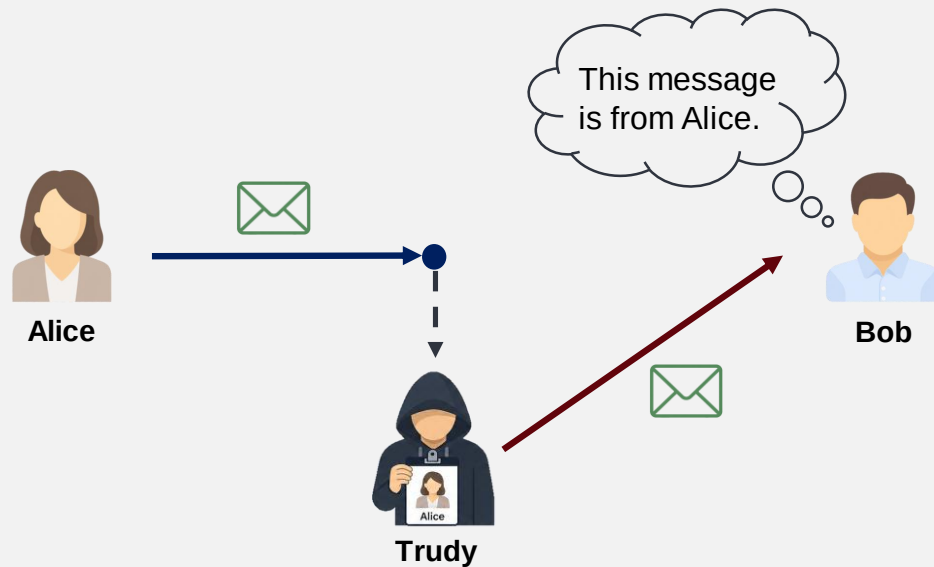
- a passive attack that observes the pattern, frequency, and length of encrypted messages to guess the nature of communication.



Cast of Characters

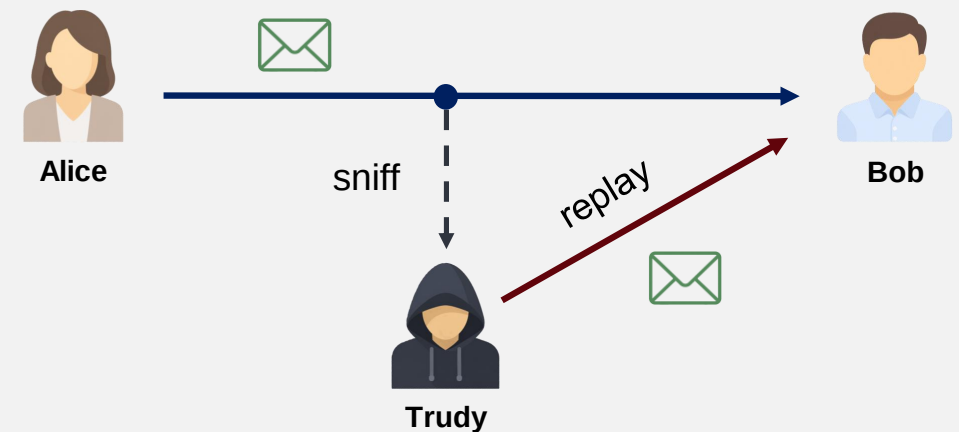
• Masquerade Attack

- an active attack where an unauthorized party pretends to be a different, authorized party to gain access.



• Replay Attack

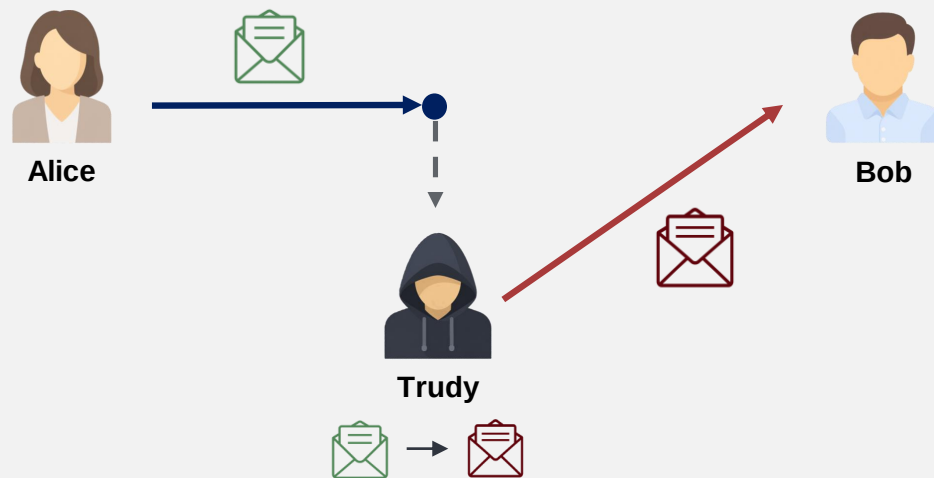
- an active attack that passively captures a data unit and subsequently retransmits it to produce an unauthorized effect.



Cast of Characters

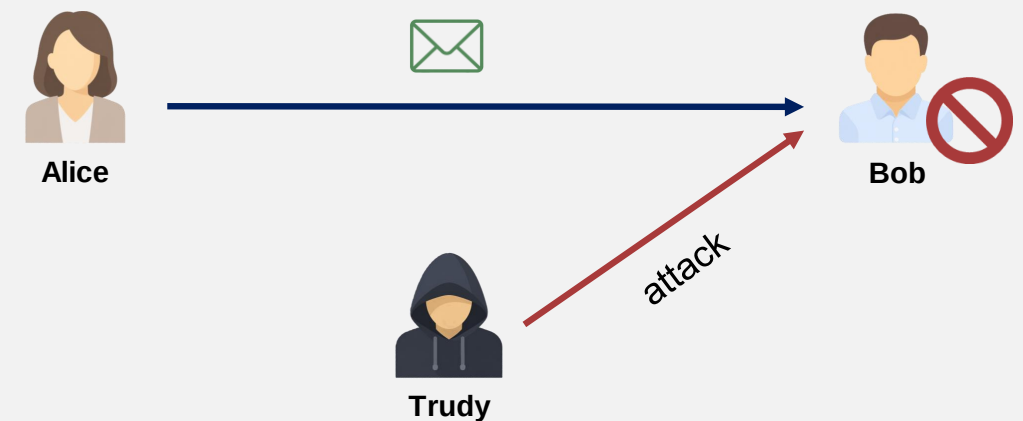
- **Modifying Messages**

- an active attack that alters, delays, or reorders a legitimate message to produce an unauthorized effect.



- **Denial-of-Service (DoS)**

- an active attack that prevents or inhibits the normal use or management of communication facilities.



Security Goals

CIA Triad: Confidentiality, Integrity, and Availability

Confidentiality

- preserves authorized restrictions on information access and disclosure.
- protects personal privacy and proprietary records from unauthorized reading.

Integrity

- guards against improper information modification or destruction.
- ensures that data and programs change only in a specified and authorized manner.

Availability

- ensures timely and reliable access to and use of information.
- guarantees that systems work promptly and service is not denied to authorized users.

Security Goals

Other Goals: Accountability, Authenticity, and Reliability

dependability

Accountability

- requires that the actions of an entity be traced uniquely to that specific entity.
- supports deterrence, fault isolation, intrusion detection, and forensic analysis.

Authenticity

- property of being genuine, verifiable, and trusted.
- provides confidence in the validity of a transmission, a message, or a message originator.

Reliability

- ensures that a system performs its intended function in an unimpaired manner without accidental failures.
- uses formal IT security management processes to preserve consistent system operations.

Security Goals

Example

Alice launches an online store called “Alice’s Market (AM).” Bob visits the website, creates an account, and decides to buy a T-shirt. He enters his credit card number to complete the purchase. Meanwhile, Trudy happens to discover the store and begins thinking about how to attack it.

Question: What are Alice’s and Bob’s security concerns? How might Trudy view the situation?

Confidentiality

Only authorized parties can access Bob’s personal and payment information.

Integrity

Bob’s order and payment details remain accurate and unchanged.

Availability

Alice’s Market remains accessible when Bob wants to shop.

Trudy may try to steal Bob’s information, alter his order, or make the store unavailable.

Security Goals

Example

Alice launches an online store called “Alice’s Market (AM).” Bob visits the website, creates an account, and decides to buy a T-shirt. He enters his credit card number to complete the purchase. Meanwhile, Trudy happens to discover the store and begins thinking about how to attack it.

Question: What are Alice’s and Bob’s security concerns? How might Trudy view the situation?

Accountability

Every action on Alice's Market is logged so that Bob's purchase or Trudy's attempted attack can be uniquely traced back to the responsible party.

Authenticity

Alice's Market correctly verifies that the person logging into the account and making the purchase is genuinely Bob and not Trudy.

Reliability

Alice's Market processes Bob's transaction consistently and operates properly without any accidental system failures.

Trudy may try to steal Bob’s information, alter his order, or make the store unavailable.

Introduction to Cybersecurity

UNIT 02.

Security Concepts and Threat Analysis



UNIT

02

Security Concepts and Threat Analysis

This unit helps you understand:

- Security Concepts and Relationships
- Attack Surfaces and Attack Trees

Security Concepts and Relationships

Asset

- a system resource or capability of value to its owner that requires protection.
- includes hardware, software, data, and communication networks needing protection.

Threat

- a potential for a threat source to exploit a vulnerability in an asset, which may compromise security and cause harm.
- represents any event capable of adversely impacting organizational operations or assets.

Vulnerability

- a flaw or weakness in an information system's design, implementation, or internal controls that could be exploited by a threat.
- leaves a system susceptible to corruption, data leakage, or service unavailability.

Attack

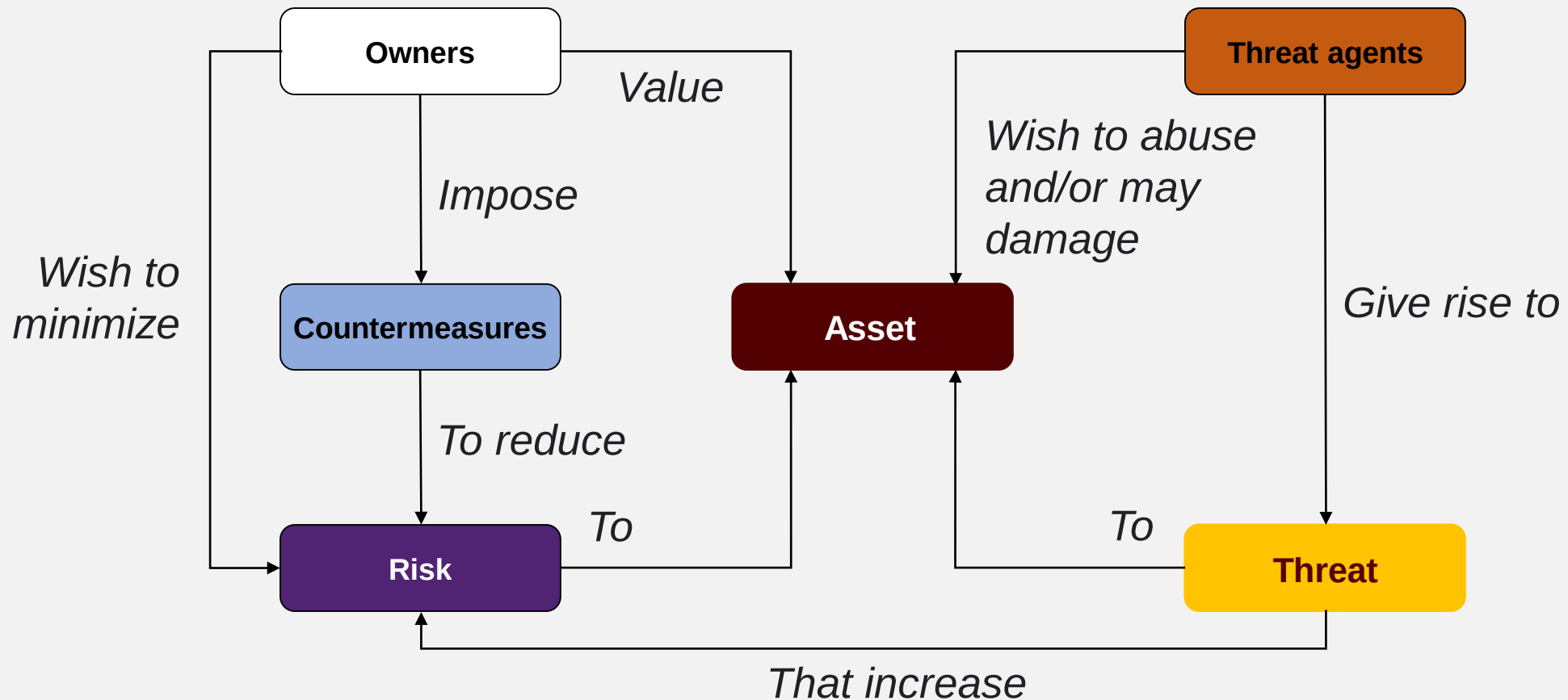
- a malicious threat that is carried out and, if successful, leads to an undesirable violation of security.
- involves active or passive attempts from inside or outside to disrupt system resources.

Control

- an action, device, procedure, or measure that reduces risk by eliminating, preventing, minimizing, or reporting a security violation.
- use management, operational, and technical categories to provide overlapping defenses.

Security Concepts and Relationships

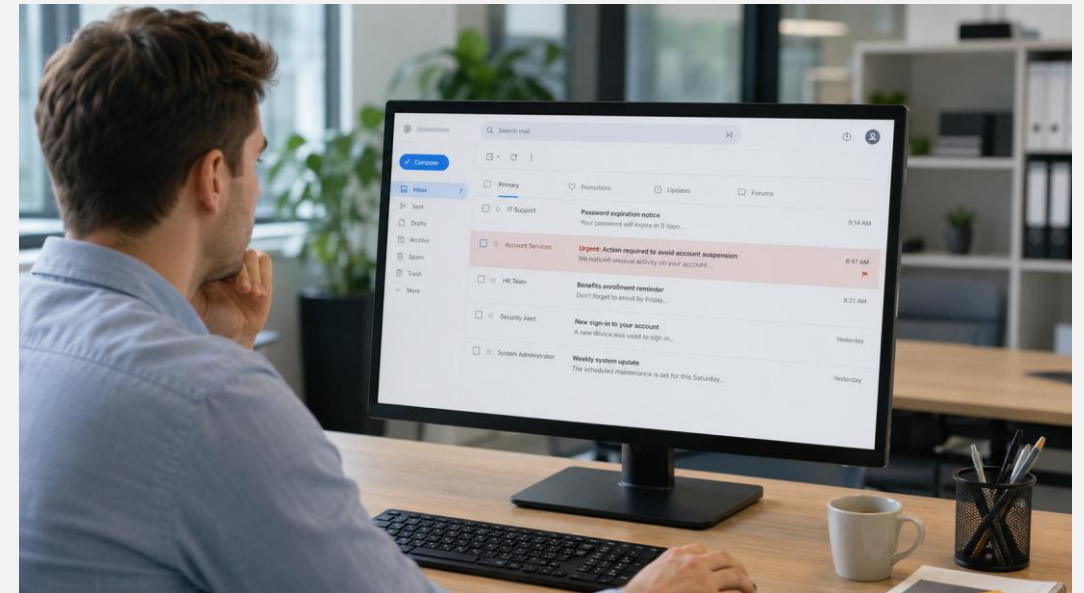
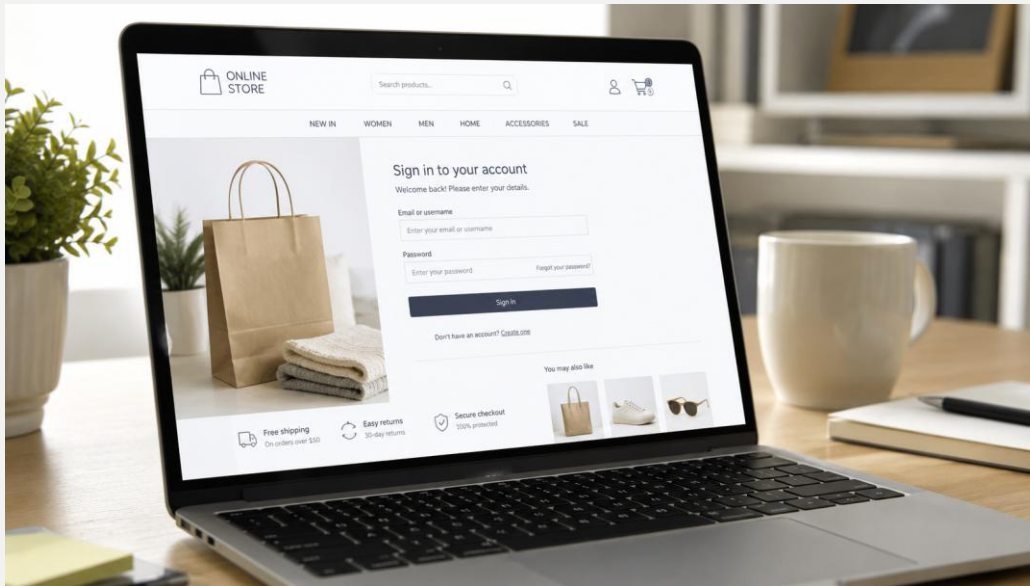
Relationships Among Assets, Threats, Vulnerabilities, Risk, and Countermeasures



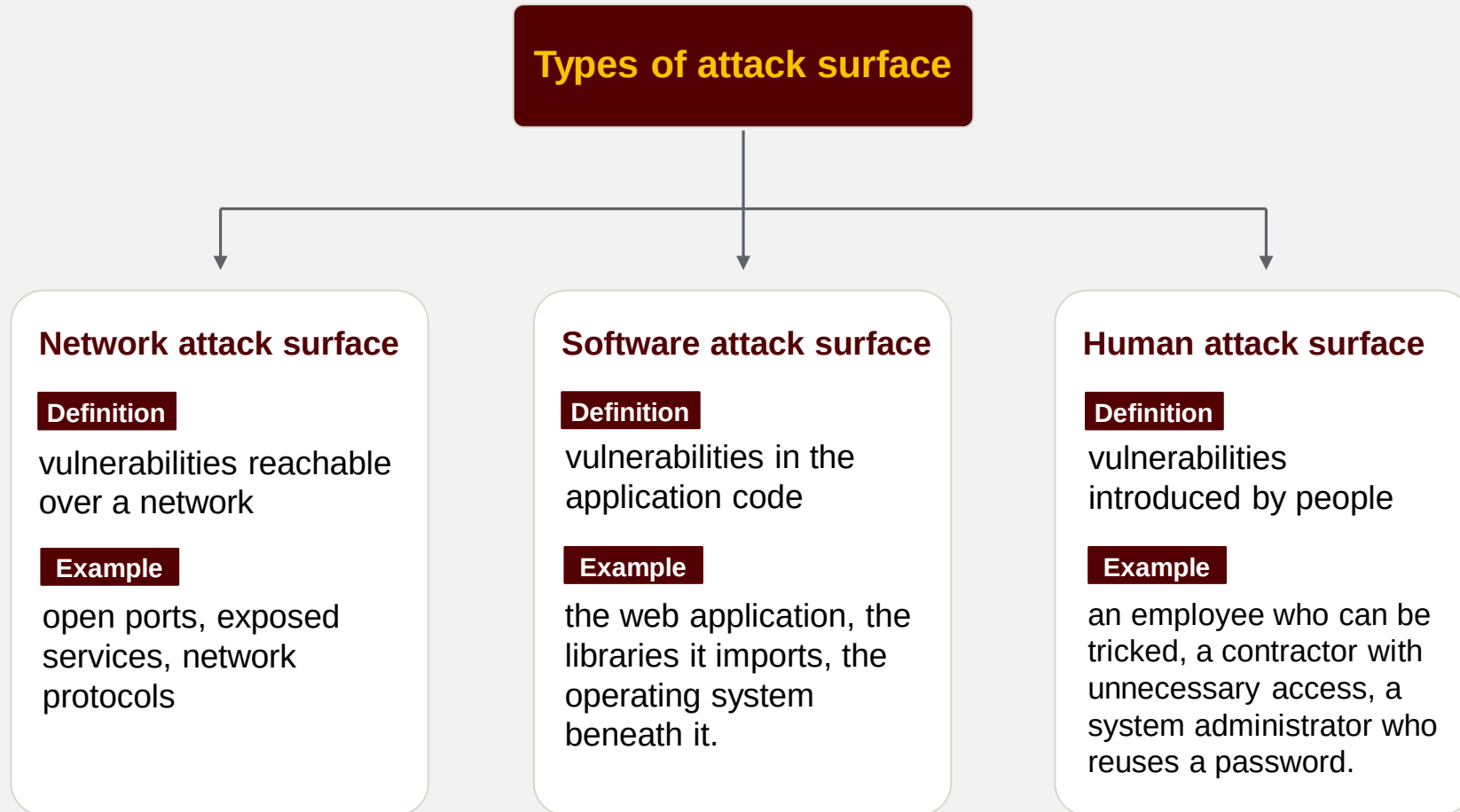
Attack Surfaces and Attack Trees

Attack Surfaces

- consists of the reachable and exploitable vulnerabilities in a system.
- categorized into network attack surfaces, software attack surfaces, and human attack surfaces.
- Analyzing the attack surface helps evaluate the scale and severity of threats and identifies where security mechanisms are required.



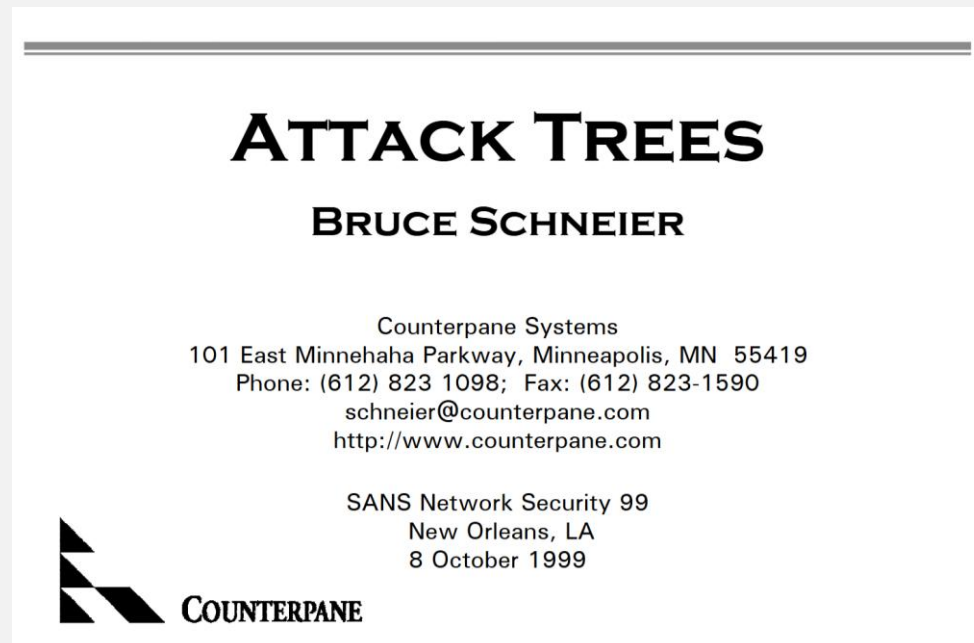
Attack Surfaces and Attack Trees



Attack Surfaces and Attack Trees

Attack Trees

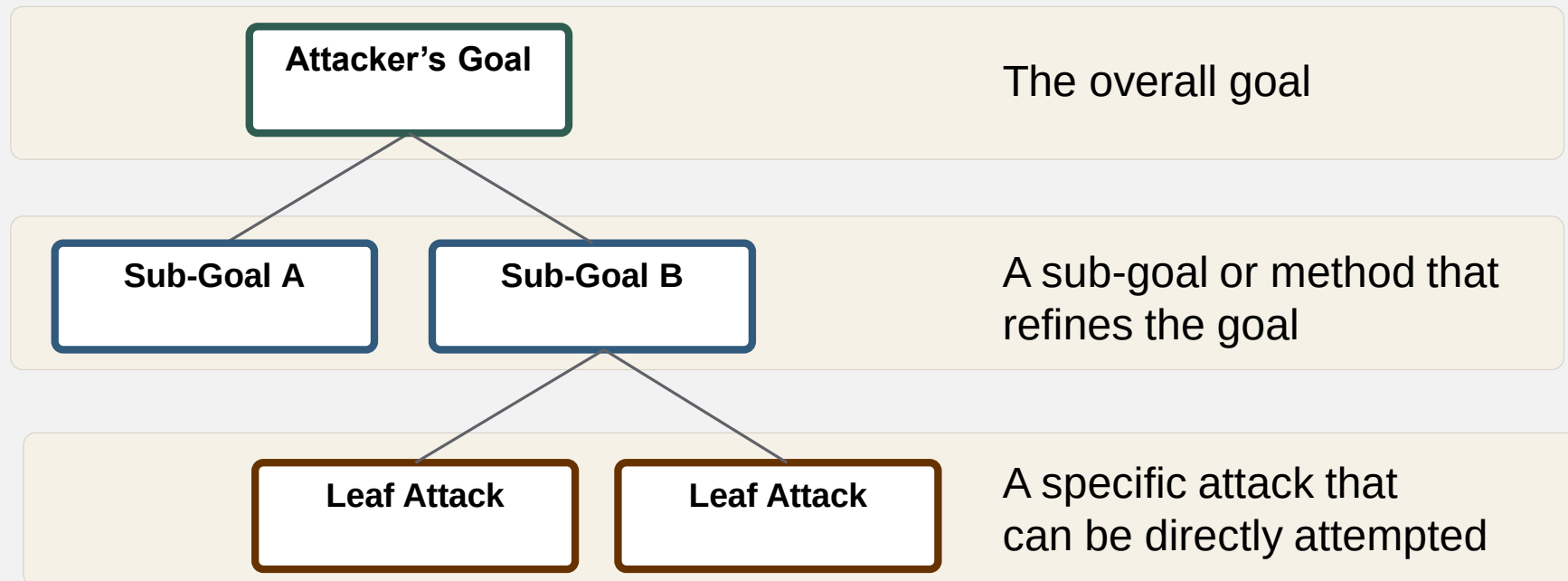
- Bruce Schneier introduced the attack tree concept in 1999 to systematically identify potential attack vectors.
- are tools to **evaluate** the system security **based on various threats**.
- provide a **formal, methodical way** of describing the security of systems.
- Represent attacks against a system in a **tree structure**.



Attack Surfaces and Attack Trees

Structure of Attack Trees

- An attack tree lays out **how a goal can be reached**.
- The **root node** represents the ultimate goal of the attacker.
- Each level breaks the goal into finer **sub-goals**, representing different ways to achieve it.
- The **leaf nodes** are the concrete, actionable attacks at the bottom of the tree.

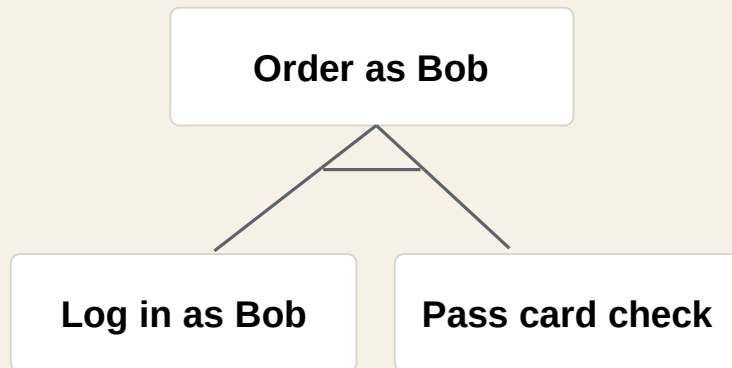


Attack Surfaces and Attack Trees

Relations

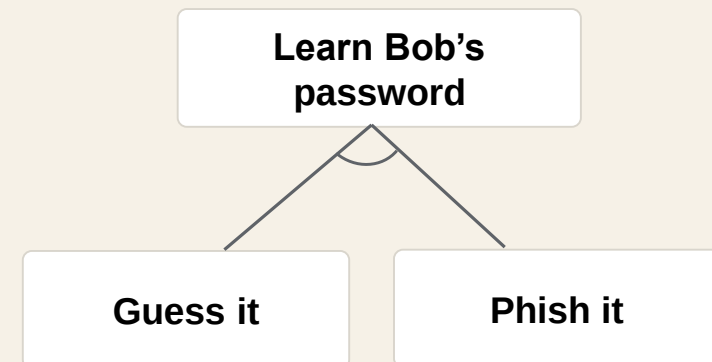
- Each node other than a leaf is either an AND-node or an OR-node.
- It determines what the attacker must achieve.
- For AND-node, the sub-goals represented by all of that node's sub-nodes must be achieved.
- For OR-node, at least one of the sub-goals must be achieved.

(1) AND-Decomposition



Trudy places a fraudulent order only if she logs in as Bob AND passes the card check — both are needed.

(2) OR-Decomposition



Trudy learns the password if she guesses it OR phishes it — one success is enough.

Key Takeaways

- Cybersecurity protects digital systems and assets in adversarial environments.
- The CIA triad—confidentiality, integrity, and availability—defines the fundamental goals of cybersecurity.
- Effective security reduces risk by identifying assets, threats, vulnerabilities, attack surfaces, and appropriate countermeasures.

Next Week: Cryptography Basics